

Wazuh: Endpoint detection and response (EDR) meets log analysis. Agent-based monitoring with rule-based detection. Good for compliance (PCI-DSS, HIPAA) and intrusion detection on hosts.

OSSEC: Host-based intrusion detection. File integrity monitoring, rootkit detection, log analysis. Lightweight. Works where agents are acceptable.

Falco: Runtime security for containers. Detects anomalous behaviour in running containers—unexpected processes, file access, network connections. Cloud-native focused.

Wireshark: The network protocol analyser. Not strictly security, but indispensable for understanding what flows through your network.

Building a defence in depth

One tool doesn't make you secure. Security lies in layers:

- **Layer 5:** Application (Trivy scans your code, ClamAV checks uploads)
- **Layer 4:** Host (OSSEC monitors file integrity, Wazuh watches logs)
- **Layer 3:** Container (Falco detects runtime anomalies, Trivy scans images)
- **Layer 2:** Network (Suricata/Snort detect intrusions, block attacks)
- **Layer 1:** Perimeter (Firewall rules, network segmentation)

For a personal server: Start with a firewall (nftables/iptables), add ClamAV for file scanning, and Trivy for any containers you run.

For a small business: Add Suricata on a network tap, Wazuh on critical servers, and automated Trivy scanning in your build pipeline.

For learning: Run Snort in a VM, attack it with Metasploit, watch the alerts. Nothing teaches security like seeing attacks in real-time.

Common beginner mistakes

- Installing everything at once. You'll generate so many alerts that real threats drown in noise. Start with one tool. Master it. Add another.
- Ignoring false positives. Snort will flag legitimate traffic. Trivy will report CVEs in packages you don't use. Don't disable rules reflexively, but don't let alert fatigue make you ignore everything.
- Running scanners on production without testing. ClamAV in real-time mode can kill I/O. Suricata in IPS mode can block legitimate users. Test in staging. Measure impact.
- Collecting logs you never review. Suricata generates gigabytes of logs. If nobody looks at them, you might as well not log. Set up automated alerting or

summary reports.

- Forgetting updates. Security tools without updated signatures are useless. Automate freshclam, suricata-update, and Trivy DB updates. Put it in cron. Monitor it.

Practical first steps

This afternoon:

1. Install Trivy.
2. Scan your most-used container image.
3. Read the first five CVEs it finds.
4. Update the base image if they're critical.

This week:

1. Set up ClamAV on your mail server or file server.
2. Create a nightly cron job to scan `/var/www/uploads` or equivalent.
3. Configure email alerts for detections.

This month:

1. Deploy Suricata on a test network segment.
2. Download the Emerging Threats ruleset. Spend two hours tuning out false positives.
3. Set up a daily report of unique alerts.

Tools don't secure systems. People do. ClamAV won't stop a user from executing a malicious attachment. Suricata won't patch your vulnerable WordPress installation. Trivy won't make you rebuild containers with updated libraries. These tools tell you what's happening. *You* have to act.

The good news? Open source security tools are mature, well-documented, and used by professionals worldwide. The knowledge is free. The software is free. Your only investment is time—and the alternative is becoming a statistic in a breach notification.

Start with one tool. Get it working. Build from there.

Your future self—awake at 2 AM during an incident—will thank you. **END** 🐧

References

- ClamAV: clamav.net
- Snort: snort.org
- Suricata: suricata.io
- Trivy: aquasecurity.github.io/trivy
- Emerging Threats rules: emergingthreats.net

By: Kousik Maiti

The author has over 18+ years of industry experience. His areas of interest include Linux systems administration, security and forensics.